Who Is Watching the Solar Farm's Network?

Student exercise · Cognton AI

The exercise at a glance

This exercise has **two parts that you do in order**.

Part A (blue) is research.

Part B (green) is a working mini prototype that is built **from** your research.

Every section in this document is coloured by the part it belongs to.

Note: All AI tools are allowed, just that you should be able to understand what AI is doing.



	PART A · RESEARCH	PART B · BUILD + VIDEO
Goal	Understand the plant, the threats, the data and the rules.	Prove the idea works by building a small "security watchman" on your laptop.
You do	6 research tasks (A1 to A6).	5 build steps (B1 to B5), plus 2 optional stretch steps.
You submit	**1 PDF research report** (6 to 10 pages).	**1 demo video** (5 to 8 minutes) Just screen recording of the prototype.
Leads to	Your last chapter is the **design for Part B**.	Your demo shows the attacks you wrote about in Part A being caught.

> **One link, three items:** your Part A report, your Part B video. All three are submitted through the submission URL in the last section.

Background: read this first

A state power company has set up one of the country's largest renewable-energy parks in the desert of western Gujarat, close to the international border. The land is split among **many developers**, each building its own solar or wind plant with equipment from **different vendors**. Each plant's inverters, meters, weather stations and sensors connect over fibre to a small, mostly **unmanned control building** (an Inverter Control Room, or ICR). Everything is run **remotely** by SCADA software, and the power flows through pooling substations into the national grid.

If someone plugged a laptop into a switch in one of those empty rooms, quietly changed an inverter's settings, or used a vendor's "maintenance" login at 2 a.m., **would anybody notice?** Today, probably not. Normal IT security tools don't understand industrial protocols, commercial OT-security products are expensive per site, the links are slow, and the developers don't share one security team.

Our product idea: a low-cost **"security watchman"**, a small box in each control room that quietly listens to the network, knows every device, spots anything unusual and reports to one central dashboard for the whole park. We plan to sell it to the park owner.

Words you will meet:

- **IT vs OT:** IT protects data; OT (Operational Technology) controls physical machines. In OT, *availability and safety come first*.
- **SCADA** and its parts: **HMI** (operator screen), **historian** (time-series database), **RTU / PLC** (field controllers), **data logger**, **inverter**, protection relays.
- **Purdue Model:** the layers of an industrial network, from Level 0 sensors up to the IT network and cloud.
- **Protocols: Modbus TCP**, **IEC 60870-5-104**, **IEC 61850**, **DNP3**, **OPC UA**, **MQTT**. Most of the older ones have **no authentication**: any device that can talk can command.
- **Passive monitoring:** copying traffic through a **mirror port or TAP**, so the sensor only listens and never sends into the control network.
- **Standards: IEC 62443**, **NIST SP 800-82 Rev. 3**, **MITRE ATT&CK for ICS**, the **CEA power-sector cybersecurity guidelines** and **CERT-In** reporting rules.

PART A · RESEARCH

Goal: understand the problem deeply enough to decide **what** the prototype in Part B must do, and **why**.

A.1 The five questions your research must answer

Pain point	Question
Many vendors, many protocols	What does a solar/wind plant network contain, and how can one tool see and understand all of it?
Empty, remote rooms	How do you detect a new or rogue device, or physical tampering, when nobody is on site?
Vendor remote access	How do equipment vendors log in today, and how can that access be time-bound, MFA-protected and recorded? How do you spot an unexpected firmware change?
Cost & skills gap	What do commercial tools cost, and what can open-source software, cheap edge hardware and ML do instead?
Slow links, no shared response	What should be processed at the site and what sent centrally? What would a shared security team and playbook look like?

A.2 Research tasks (one chapter each)

A1 — **Draw the plant.** Make a reference architecture of one solar plant: panels → inverters → ICR switch/data logger → plant SCADA → pooling substation → grid control centre, plus the vendor's remote-access path. Label the Purdue level and protocol on every link.
Output: *one diagram and a table of devices and protocols.*

A2 — **Listen to the machines.** Open public ICS packet captures in **Wireshark** (e.g., Netresec 4SICS captures, ITI ICS-Security-Tools pcaps on GitHub). Find a Modbus *read*, a Modbus *write* and an IEC-104 command. Note which protocols have any authentication.
Output: *annotated screenshots and "what an attacker could send" for each protocol.*

A3 — **Study real attacks.** Ukraine grid attacks 2015/2016 (BlackEnergy, Industroyer), Industroyer2 (2022), TRITON (2017), the 2022 KA-SAT outage that cut remote monitoring of ~5,800 German wind turbines, reports of groups targeting India's grid (e.g., "RedEcho", 2021) and Volt Typhoon. Map each to **MITRE ATT&CK for ICS**. Then write **8 to 10 attack scenarios for a solar park** (rogue laptop in the ICR, changed inverter set-point, abused vendor login, malicious firmware, flood on the IEC-104 link…).
Output: *case-study table and scenario list.*

A4 — **Hunt for data.** Compare public datasets on protocols, size, labelled attacks and licence: **CIC Modbus 2023**, **HAI**, **SWaT / WADI** (access on request), **Electra**, the **DNP3 intrusion dataset** (Zenodo), Mississippi State power-system datasets and IEC-104 datasets. List what data a real ICR would give us (pcaps, switch tables, logs, SCADA alarms, inverter registers).
Output: *comparison table and a recommendation.*

A5 — **Learn the rules.** Summarise what the CEA guidelines, IEC 62443 and CERT-In require. Draft a **one-page playbook** for "rogue device found in ICR": who is alerted, what is isolated, what is reported, and by when.
Output: *compliance checklist and the playbook.*

A6 — **Know the market.** Compare Nozomi Networks, Claroty, Dragos, Tenable OT, Microsoft Defender for IoT and open-source stacks (Security Onion, Malcolm) on features, deployment and pricing signals. Who would pay, and how?
Output: *comparison table and a one-paragraph product pitch.*

A.3 Bridge to Part B: your prototype design (final chapter)

End your report with a **1 to 2 page design for Part B**. This is what connects the two parts. It must state:

- **Which 4 or more attack scenarios** from A3 your prototype will detect.
- **Which data** you will use (lab traffic, a dataset from A4, or both).
- **Your architecture:** the simulated devices, the sensor, the detection logic and the dashboard.
- **How you will measure success** against the targets in B.2.

A.4 What you submit for Part A

PART A DELIVERABLE

One PDF research report, 12 to 20 pages, shared as a link (Google Drive or similar, viewable by anyone with the link). It contains:

- Chapters A1 to A6, plus the prototype design chapter (A.3).
- 3 open questions you could not answer.
- References: papers, standards and vendor documents. Diagrams beat paragraphs.

PART B · BUILD THE PROTOTYPE + RECORD A VIDEO

Goal: build the design from your Part A report as a working **mini control room on your laptop** that catches your attack scenarios.

Everything runs **locally** (e.g., Docker Compose). There is no real plant and nothing connected to the internet. Steps B1 to B5 are **required**; B6 and B7 are optional stretch goals.

B.1 Build steps

B1	**Simulate a mini-ICR.** At least **3 fake inverters** (pymodbus Modbus TCP servers with registers for power, voltage and set-point), **1 RTU/PLC** (OpenPLC), **1 IEC-104 link** to a fake grid control centre (lib60870) and an **HMI** (ScadaBR or FUXA) polling them normally.
B2	**Add a passive sensor.** Mirror the Docker network's traffic to a sensor running **Zeek with CISA ICSNPP parsers** and/or **Suricata**. Show that SCADA polling is unaffected.
B3	**Build the device inventory.** Build a **live device list** from traffic (IP, MAC, protocol, role, first and last seen) and raise an alert when an **unknown device** appears.
B4	**Detect attacks. Rules** (who may write which register, from where, when) plus **ML** (e.g., Isolation Forest or an autoencoder trained on normal traffic). Each alert must say *why* it fired, in plain words.
B5	**Attack it and show the dashboard.** Run **at least 4 scenarios from your Part A design** against the lab. Show the inventory, the alerts and a timeline on a simple dashboard (Grafana, Kibana or Streamlit).
B6	**Stretch: secure vendor access.** A remote-access gateway (e.g., Apache Guacamole) with **MFA**, time-limited access and **session recording**.
B7	**Stretch: slow-link mode.** Send only alerts and small summaries to the dashboard, and measure KB per hour.

B.2 Targets your demo should show

Target	How to show it
Every device found	The inventory lists all simulated devices, and the rogue device is flagged.
≥ 95% of attacks detected	Every scenario you run produces the right alert.
< 5% false alarms	Run normal traffic for a while and count any alerts.
Detects in under ~15 minutes	Show each attack time next to its alert time.
No impact on control traffic	SCADA polling keeps working with the sensor on.

B.3 What you submit for Part B

PART B DELIVERABLE

1. A demo video, 5 to 8 minutes, Google Drive link.

1. Show your architecture diagram from the Part A design chapter.
2. Show the lab running normally, with the inventory filling up.
3. Run each attack live and show the alert and its reason.
4. Show your results against the B.2 targets, and one thing that did not work.

Rules for both parts

Safety & ethics: never scan, probe or attack any real industrial network or internet-exposed device (including via Shodan). A careless scan can crash a PLC. All attack work stays inside your own local lab.

Expect these hurdles and write about them: no access to a real plant, few labelled attack datasets, false alarms that make operators stop trusting a tool, proprietary vendor protocols, and harsh field conditions (heat, dust, power cuts, slow links).

Submission

SUBMIT ALL THREE LINKS HERE

[https://forms.gle/DN8N9JVxhCZn2X1r5]

Part	Item	Format
PART A	**Research report**	PDF link, 12 to 20 pages, viewable by anyone with the link
PART B	**Demo video**	Google Drive link, (Just screen recording of the prototype.)
Submit A & B	**Research report + Video**	

Before you submit: checklist

- ☐ **Part A:** report covers A1 to A6, the prototype design chapter, open questions and references.
- ☐ **Part B:** at least 4 attack scenarios from the Part A design are demonstrated and detected.
- ☐ **Part B:** video is 5 to 8 minutes, (Just screen recording of the prototype.) and the link opens without asking for permission.
- ☐ **Part B:** repository has a README and runs with docker-compose.
- ☐ All three links are submitted through the submission URL.

After you submit, we meet **in person** to walk through your research and demo. Bring three questions you couldn't answer. Your curiosity matters more than perfection.

Starter reading: NIST SP 800-82 Rev. 3 · MITRE ATT&CK for ICS · ISA/IEC 62443 overview · CEA Cyber Security Guidelines for the Power Sector · SANS ICS resources · Dragos Year-in-Review · CISA ICSNPP and Malcolm (GitHub) · pymodbus, OpenPLC and lib60870 docs.